

AWS Secure Web Application Deployment

with High Availability and Cloud Security

Table of Contents

Table of Contents.....	2
1. Project Overview	3
2. Objectives	3
3. Architecture Diagram	4
4. Architecture Explanation	5
4.1 Public Layer.....	5
4.2 Private Web Layer	5
4.3 Private Database Layer	5
5. AWS Services Used.....	6
6. VPC Configuration	7
7. Subnets.....	8
8. Route Tables.....	9
9. Security Groups	10
10. IAM Role	12
11. Bastion Host.....	13
12. Custom AMI and Web Server Build	14
13. Launch Template	15
14. Auto Scaling Group	16
15. Load Balancer	17
16. AWS WAF.....	18
17. Amazon RDS	18
18. AWS Secrets Manager.....	19
19. AWS KMS	20
20. Amazon CloudWatch	21
21. Amazon SNS	21
22. AWS CloudTrail	22
23. Amazon S3	23
24. Traffic Flow	23
Application Request Flow	23
Administrative Access Flow	23
25. Security Best Practices Applied.....	23
26. Challenges Faced	24
27. Future Improvements	24
28. Conclusion	24

1. Project Overview

This project demonstrates the deployment of a secure, three-tier web application on Amazon Web Services, designed around the AWS Well-Architected Framework's security and reliability pillars. The infrastructure separates the application into public, private-web, and private-database layers across two Availability Zones, achieving both network isolation and high availability.

The environment includes a custom VPC with public and private subnets, a Bastion Host for controlled administrative access, an internet-facing Application Load Balancer protected by AWS WAF, an Auto Scaling Group of Windows/IIS web servers built from a custom AMI, a Multi-AZ Amazon RDS for MySQL database, IAM least-privilege roles, AWS Secrets Manager for credential storage, and a full observability stack using CloudWatch, SNS, CloudTrail, and S3.

2. Objectives

- Design and deploy a secure, segmented AWS network using a custom VPC.
- Separate public, private-web, and private-database resources using subnets and route tables.
- Provide controlled administrative access through a Bastion Host instead of exposing servers directly.
- Deploy a highly available, internet-facing Application Load Balancer protected by AWS WAF.
- Achieve elasticity and fault tolerance using a Launch Template and Auto Scaling Group.
- Store the application database on Multi-AZ Amazon RDS for MySQL inside a private subnet.
- Protect application secrets using AWS Secrets Manager and IAM roles instead of hard-coded credentials.
- Encrypt data at rest using AWS KMS.
- Implement centralized logging and monitoring with CloudTrail, CloudWatch, SNS, and S3.
- Follow the principle of least privilege across all IAM roles and security groups.

3. Architecture Diagram

The diagram below illustrates the complete deployment: traffic flow from the client through AWS WAF, the Application Load Balancer, the Auto Scaling web tier, and into the Multi-AZ RDS database, alongside the supporting security, identity, and monitoring services.

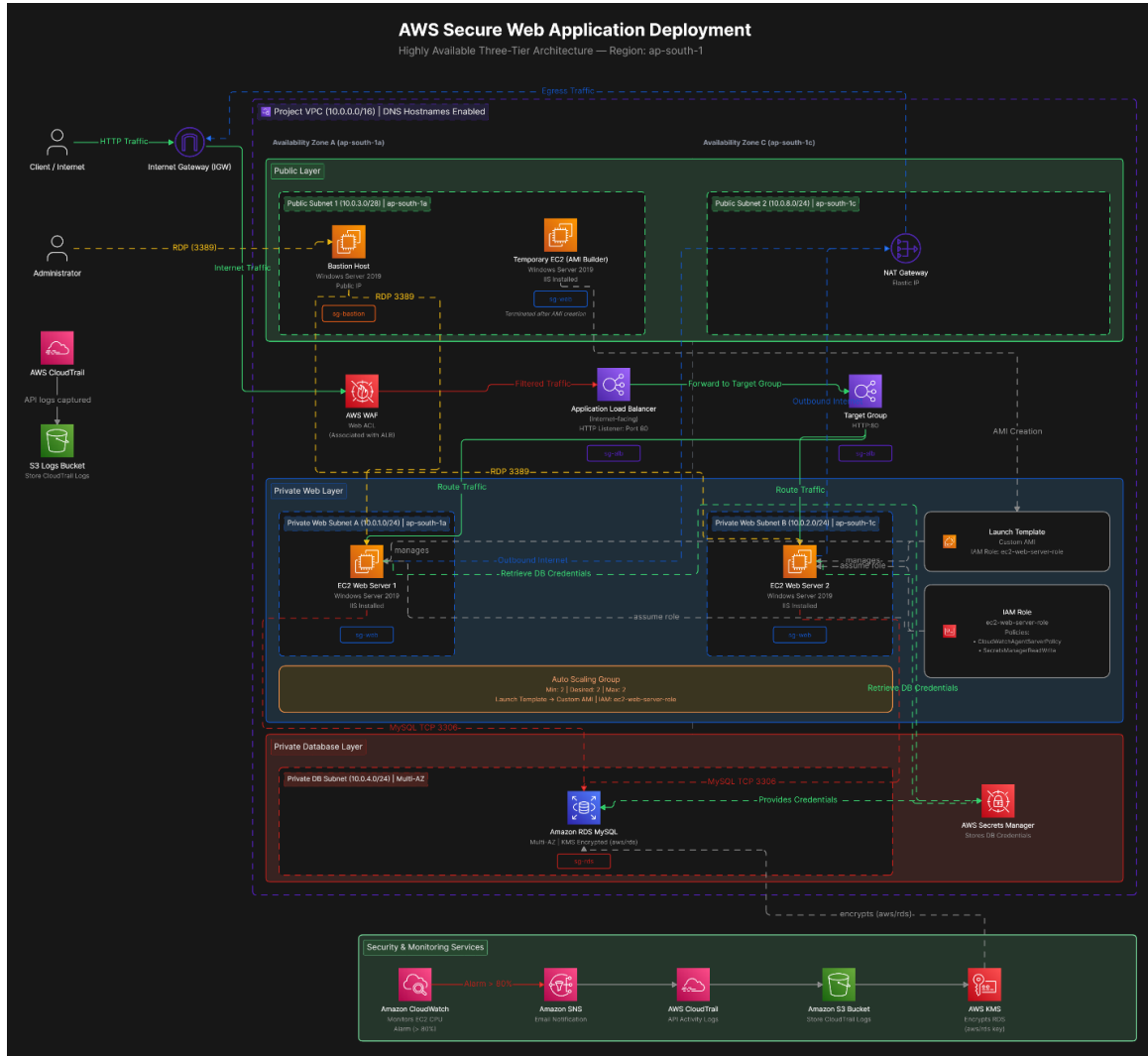


Figure 1 — AWS Secure Web Application Deployment: complete architecture

4. Architecture Explanation

4.1 Public Layer

The public layer hosts every component that needs to communicate directly with the internet.

- Internet Gateway — attaches the VPC to the internet and is the only entry/exit point for public traffic.
- Public Subnet A & B — host internet-facing resources across two Availability Zones for resilience.
- Bastion Host — a Windows Server instance with a public IP that administrators RDP into before reaching private servers, so no web server is ever exposed directly to the internet.
- Temporary EC2 (AMI Builder) — a short-lived instance used only to install IIS and prepare the application, then captured as a custom AMI and terminated.
- NAT Gateway — lets instances in the private subnets reach the internet for updates without being reachable from it.
- Application Load Balancer — the internet-facing entry point for application traffic, distributing requests across both Availability Zones.
- AWS WAF — a Web ACL attached to the ALB that filters malicious or unwanted traffic before it ever reaches the application.

4.2 Private Web Layer

The private web layer runs the application itself, fully isolated from direct internet access.

- Launch Template — defines the custom AMI, instance type, IAM role, and security group used for every new web server.
- Auto Scaling Group — keeps a minimum, desired, and maximum of two healthy IIS web servers running across both Availability Zones.
- EC2 Web Server 1 & 2 — Windows Server 2019 instances running IIS, reachable only from the ALB (HTTP) and the Bastion Host (RDP).
- IAM Role (ec2-web-server-role) — grants the web servers permission to push metrics to CloudWatch and read secrets from Secrets Manager, without embedding credentials on the instance.

4.3 Private Database Layer

The database layer is the most restricted tier in the architecture.

- Amazon RDS for MySQL — deployed Multi-AZ for automatic failover, placed in a private subnet with no public access.
- Private DB Subnet — accepts inbound MySQL traffic only from the web tier security group.
- AWS KMS Encryption — encrypts the RDS storage at rest using a dedicated aws/rds key.

5. AWS Services Used

Service	Purpose
Amazon VPC	Network isolation across public and private subnets
Amazon EC2	Hosts the Bastion Host and IIS web servers
Application Load Balancer (ALB)	Distributes incoming HTTP traffic across web servers
AWS WAF	Filters malicious traffic before it reaches the ALB
Auto Scaling Group (ASG)	Maintains web server availability and elasticity
IAM	Least-privilege roles and permissions for EC2 instances
AWS Secrets Manager	Securely stores and serves database credentials
Amazon RDS (MySQL)	Multi-AZ relational database for the application
AWS KMS	Encrypts RDS storage at rest
NAT Gateway	Provides outbound-only internet access for private subnets
Amazon CloudWatch	Monitors EC2 CPU utilization and raises alarms
Amazon SNS	Sends email notifications for CloudWatch alarms
AWS CloudTrail	Logs all API activity across the account
Amazon S3	Stores CloudTrail audit logs

6. VPC Configuration

The project VPC was created with a 10.0.0.0/16 CIDR block and DNS hostnames enabled, spanning two Availability Zones (ap-south-1a and ap-south-1c) in the Asia Pacific (Mumbai) region for resilience against single-AZ failure.

vpc-047202d0389c330cd / websec

Actions

Details

VPC ID

vpc-047202d0389c330cd

DNS resolution

Enabled

Main network ACL

acl-0a663830ceb41f7ef

IPv6 CIDR (Network border group)

-

Encryption control ID

-

State

Available

Tenancy

default

Default VPC

No

Network Address Usage metrics

Disabled

Encryption control mode

-

Block Public Access

Off

DHCP option set

dopt-06db79799e9529bb0

IPv4 CIDR

10.0.0.0/16

Route 53 Resolver DNS Firewall rule groups

-

DNS hostnames

Disabled

Main route table

rtb-0a33aa46bfe733f1e

IPv6 pool

-

Owner ID

369113522455

Resource map

CIDRs

Flow logs

Tags

Integrations

Resource map

Show all details

VPC

Your AWS virtual network

websec

Subnets (6)

Subnets within this VPC

ap-south-1a

pubsub-bastion

privatesub-rdsmysql

privatesub-ser-1

ap-south-1b

websec-rds-2

ap-south-1c

publicsub-natgateway

privatesub-ser-2

Route tables (4)

Route network traffic to resources

RDS-mysql

webser1-and-2

natgateway-and-bastionhost

rtb-0a33aa46bfe733f1e

Network Connections (2)

Connections to other networks

websec-IGW

natgatewayforwebsec

7. Subnets

Each tier of the application sits in its own subnet so that network access can be controlled independently at every layer:

- Public Subnets — host the Bastion Host, NAT Gateway, and Application Load Balancer.
- Private Web Subnets — host the IIS web server EC2 instances, reachable only through the ALB and Bastion.
- Private DB Subnet — hosts the Multi-AZ RDS MySQL instance, reachable only from the web tier.

The screenshot shows the AWS VPC dashboard. On the left is a navigation menu with options like 'Virtual private cloud', 'Subnets', 'Route tables', 'Internet gateways', etc. The main panel displays a table of subnets for VPC vpc-047202d0389c330cd. Below the table, the details for subnet-0199ef681d5896177 are shown, including its ID, ARN, state (Available), IPv4 CIDR (10.0.4.0/28), availability zone (aps1-az1), network ACL, and various settings for public access, auto-assigning IP addresses, and DNS records.

Name	Subnet ID	State	VPC	Block Public...	IPv4 CIDR
privatesub-rdsmysql	subnet-0199ef681d5896177	Available	vpc-047202d0389c330cd web...	Off	10.0.4.0/28
-	subnet-01c90daaf7d97420a	Available	vpc-0cf4c33e8e6fbacb7	Off	172.31.0.0/20
privatesub-ser-1	subnet-0f91c5d0c43e30c61	Available	vpc-047202d0389c330cd web...	Off	10.0.1.0/24
publicsub-natgateway	subnet-00e2b3a88768ec393	Available	vpc-047202d0389c330cd web...	Off	10.0.5.0/24

subnet-0199ef681d5896177 / privatesub-rdsmysql

- Subnet ID:** subnet-0199ef681d5896177
- Subnet ARN:** arn:aws:ec2:ap-south-1:369113522455:subnet/subnet-0199ef681d5896177
- State:** Available
- IPv4 CIDR:** 10.0.4.0/28
- Availability Zone:** ap-south-1a
- Network ACL:** acl-0a663830ceb41f7ef
- Auto-assign customer-owned IPv4 address:** No
- IPv6 CIDR reservations:** No
- Resource name DNS AAAA record:** Disabled
- Available IPv4 addresses:** 10
- Network border group:** ap-south-1
- Default subnet:** No
- Customer-owned IPv4 pool:** No
- IPv6-only:** No
- DNS64:** Disabled
- VPC:** vpc-047202d0389c330cd | websec
- Auto-assign public IPv4 address:** No
- Outpost ID:** No
- Hostname type:** IP name
- Owner:** 369113522455
- Block Public Access:** Off
- IPv6 CIDR association ID:** No
- Route table:** rtb-05673239e70baa5be | RDS-mysql
- Auto-assign IPv6 address:** No
- IPv4 CIDR reservations:** No
- Resource name DNS A record:** Disabled

Subnet list — public and private subnets across the VPC

This screenshot shows a different view of the AWS VPC dashboard, focusing on a different set of subnets. The table lists subnets including 'websec-rds-2', 'pubsub-bastion', and 'privatesub-ser-2'. The detailed view for subnet-098e69a4745619065 is expanded, showing its configuration details.

Name	Subnet ID	State	VPC	Block Public...	IPv4 CIDR
websec-rds-2	subnet-018c5fca4f1225fda	Available	vpc-047202d0389c330cd web...	Off	10.0.6.0/28
pubsub-bastion	subnet-098e69a4745619065	Available	vpc-047202d0389c330cd web...	Off	10.0.3.0/28
privatesub-ser-2	subnet-0d7a6ee33d1c61e0f	Available	vpc-047202d0389c330cd web...	Off	10.0.2.0/24

subnet-098e69a4745619065 / pubsub-bastion

- Subnet ID:** subnet-098e69a4745619065
- Subnet ARN:** arn:aws:ec2:ap-south-1:369113522455:subnet/subnet-098e69a4745619065
- State:** Available
- IPv4 CIDR:** 10.0.3.0/28
- Availability Zone:** ap-south-1a
- Network ACL:** acl-0a663830ceb41f7ef
- Auto-assign customer-owned IPv4 address:** No
- IPv6 CIDR reservations:** No
- Resource name DNS AAAA record:** Disabled
- Available IPv4 addresses:** 9
- Network border group:** ap-south-1
- Default subnet:** No
- Customer-owned IPv4 pool:** No
- IPv6-only:** No
- DNS64:** Disabled
- VPC:** vpc-047202d0389c330cd | websec
- Auto-assign public IPv4 address:** No
- Outpost ID:** No
- Hostname type:** IP name
- Owner:** 369113522455
- Block Public Access:** Off
- IPv6 CIDR association ID:** No
- Route table:** rtb-0de6cd9173352922 | natgateway-and-bastionhost
- Auto-assign IPv6 address:** No
- IPv4 CIDR reservations:** No
- Resource name DNS A record:** Disabled

Public subnet detail — publicsub-bastion

Subnets (1/9) info

Name	Subnet ID	State	VPC	Block Public...	IPv4 CIDR
websec-rds-2	subnet-018c5fca4f1225fda	Available	vpc-047202d0389c330cd web...	Off	10.0.6.0/28
pubsub-bastion	subnet-098e69a4745619065	Available	vpc-047202d0389c330cd web...	Off	10.0.3.0/28
privatesub-ser-2	subnet-0d7a6ee33d1c61e0f	Available	vpc-047202d0389c330cd web...	Off	10.0.2.0/24

subnet-0d7a6ee33d1c61e0f / privatesub-ser-2

Subnet ID subnet-0d7a6ee33d1c61e0f	Subnet ARN arn:aws:ec2:ap-south-1:3691135224:55:subnet/subnet-0d7a6ee33d1c61e0f	State Available	Block Public Access Off
IPv4 CIDR 10.0.2.0/24	Available IPv4 addresses 250	IPv6 CIDR -	IPv6 CIDR association ID -
Availability Zone ap-south-1	Network border group ap-south-1	VPC vpc-047202d0389c330cd websec	Route table rtb-074e88d48f07b1804 webser1-and-2
Network ACL acl-0a663830ceb41f7ef	Default subnet No	Auto-assign public IPv4 address No	Auto-assign IPv6 address No
Auto-assign customer-owned IPv4 address No	Customer-owned IPv4 pool -	Outpost ID -	IPv4 CIDR reservations -
IPv6 CIDR reservations -	IPv6-only No	Hostname type IP name	Resource name DNS A record Disabled
Resource name DNS AAAA record Disabled	DNS64 Disabled	Owner 369113522455	

Private subnet detail — webser-1 / privatesub-ver-1

8. Route Tables

Three route tables enforce the traffic boundaries between tiers:

Public Route Table — 0.0.0.0/0 → Internet Gateway

Private Web Route Table — 0.0.0.0/0 → NAT Gateway

Private DB Route Table — local route only (no internet path)

Route tables (1/5) info

Name	Route table ID	Explicit subnet associ...	Edge associations	Main	VPC
-	rtb-02a6612f6ba0170e2	-	-	Yes	vpc-0cf4c33e8e6fbac7
RDS-mysql	rtb-05673239e70baa5be	subnet-0199ef681d5896...	-	No	vpc-047202d0389c330cd we
webser1-and-2	rtb-074e88d48f07b1804	2 subnets	-	No	vpc-047202d0389c330cd we
natgateway-and-bastionhost	rtb-0de6c0d9173352922	2 subnets	-	No	vpc-047202d0389c330cd we

rtb-05673239e70baa5be / RDS-mysql

Destination	Target	Status	Propagated	Route Origin
fd00:ec2:80:/64	VpLattice	Active	No	Create Route
10.0.0.0/16	local	Active	No	Create Route Table
169.254.171.0/24	VpLattice	Active	No	Create Route

Route tables overview, including the RDS-mysql local-only table

Route tables (1/5)

Name	Route table ID	Explicit subnet associ...	Edge associations	Main	VPC
-	rtb-02a6612f6ba0170e2	-	-	Yes	vpc-0cf4c33e8e6fbac7
☒ RDS-mysql	rtb-05673239e70baa5be	subnet-0199ef681d5896...	-	No	vpc-047202d0389c330cd we
☐ webser1-and-2	rtb-074e88d48f07b1804	2 subnets	-	No	vpc-047202d0389c330cd we
☐ natgateway-and-bastionhost	rtb-0de6c0d9173352922	2 subnets	-	No	vpc-047202d0389c330cd we

rtb-05673239e70baa5be / RDS-mysql

Subnet associations (1)

Name	Subnet ID	IP v4 CIDR	IP v6 CIDR
privatesub-rdsmysql	subnet-0199ef681d5896177	10.0.4.0/28	-

Subnets without explicit associations (1)

The following subnets have not been explicitly associated with any route tables and are therefore associated with the main route table:

Name	Subnet ID	IP v4 CIDR	IP v6 CIDR
websec-rds-2	subnet-018c5fca4f1225fda	10.0.6.0/28	-

Private DB route table — subnet associations

9. Security Groups

Security Group	Inbound Rules
sg-bastion	TCP 3389 (RDP) from administrator IP only
sg-alb	TCP 80 (HTTP) from 0.0.0.0/0
sg-web	TCP 80 from sg-alb; TCP 3389 (RDP) from sg-bastion
sg-rds	TCP 3306 (MySQL) from sg-web (and optionally sg-bastion)

Security Groups (1/13)

Name	Security group ID	Security group name	VPC ID	Description
-	sg-002bad26760b94bdb	default	vpc-047202d0389c330cd	default VPC secur
☒ -	sg-0914cb3ec17c5a267	load-balancer-Sg	vpc-047202d0389c330cd	load-balancer-Sg
☐ -	sg-0abba2daccfc33216	amitem	vpc-047202d0389c330cd	amitem
☐ -	sg-0ba11d8d9abd0a1f6	launch-wizard-2	vpc-047202d0389c330cd	launch-wizard-2 c

sg-0914cb3ec17c5a267 - load-balancer-Sg

Inbound rules (1)

Security group rule ID	IP version	Type	Protocol	Port range	Source
sgr-0a6f173cddcf6b481	IPv4	HTTP	TCP	80	0.0.0.0/0

Security groups overview

Security Groups

Find security groups by attribute or tag

Security Groups (1/13)

Info

Actions

Export security groups to CSV

Create security group

Name	Security group ID	Security group name	VPC ID	Description
-	sg-002bad26760b94bdb	default	ypc-047202d0389c330cd	default VPC secur
☒	sg-0914cb3ec17c5a267	load-balancer-Sg	ypc-047202d0389c330cd	load-balancer-Sg
☐	sg-0abbba2daccfc33216	amitem	ypc-047202d0389c330cd	amitem
☐	sg-0ba11d8d9abd0a1f6	launch-wizard-2	ypc-047202d0389c330cd	launch-wizard-2 c

sg-0914cb3ec17c5a267 - load-balancer-Sg

Details

Inbound rules

Outbound rules

Sharing

VPC associations

Related resources - new

Tags

Inbound rules (1)

Manage tags

Edit inbound rules

Search

Security group rule ID	IP version	Type	Protocol	Port range	Source
sgr-0a6f173cddcf6b481	IPv4	HTTP	TCP	80	0.0.0.0/0

load-balancer-sg — inbound rule (HTTP from internet)

EC2

Find security groups by attribute or tag

Security Groups (1/13)

Info

Actions

Export security groups to CSV

Create security group

Name	Security group ID	Security group name	VPC ID	Description
☐	sg-0ba11d8d9abd0a1f6	launch-wizard-2	ypc-047202d0389c330cd	launch-wizard-2 c
☐	sg-0a611bbc2f6b9bcc02	launch-wizard-3	ypc-0cf4c33e8e6fbac7	launch-wizard-3 c
☐	sg-0cdd5b5d1e7735d5e	launch-wizard-1	ypc-047202d0389c330cd	launch-wizard-1 c
☒	sg-02e10f18622c6e029	webser-SG	ypc-047202d0389c330cd	webser-SG

sg-02e10f18622c6e029 - webser-SG

Details

Inbound rules

Outbound rules

Sharing

VPC associations

Related resources - new

Tags

Inbound rules (2)

Manage tags

Edit inbound rules

Search

Name	Security group rule ID	IP version	Type	Protocol	Port range
-	sgr-0231039713ebbbe3	-	RDP	TCP	3389
-	sgr-07a82d7343c96f8ab	-	HTTP	TCP	80

web-SG — inbound rules (HTTP from ALB, RDP from Bastion)

The screenshot shows the AWS Management Console interface for Security Groups. The left sidebar lists navigation options like EC2, IAM, and CloudWatch. The main content area displays the 'Security Groups (1/13) Info' page. A table lists three security groups: 'default', 'bastion-host-sg', and 'bastion-SG'. The 'bastion-SG' group is selected, and its details are shown below. The 'Inbound rules' tab is active, displaying a table of two rules: one for SSH (port 22) and one for RDP (port 3389).

Name	Security group ID	Security group name	VPC ID	Description
-	sg-0df21dae36e822f35	default	vpc-0cf4c33e866fbach7	default VPC secur
-	sg-0f9fa048241add2cd	bastion-host-sg	vpc-047202d0389c330cd	bastion-host-sg
☒	sg-0fc675a292d212c04	bastion-SG	vpc-047202d0389c330cd	bastion-SG

Name	Security group rule ID	IP version	Type	Protocol	Port range
-	sgr-05c5f307f38f8a3ff	IPv4	SSH	TCP	22
-	sgr-066faf248fe40dff04	IPv4	RDP	TCP	3389

bastion-SG — inbound RDP rule

10. IAM Role

The EC2 web servers run under a dedicated IAM role rather than embedded credentials. The role is attached to the instance profile and grants exactly two managed policies:

- CloudWatchAgentServerPolicy — allows the instance to publish custom metrics and logs to CloudWatch.
- SecretsManagerReadWrite — allows the instance to retrieve database credentials from Secrets Manager at runtime.

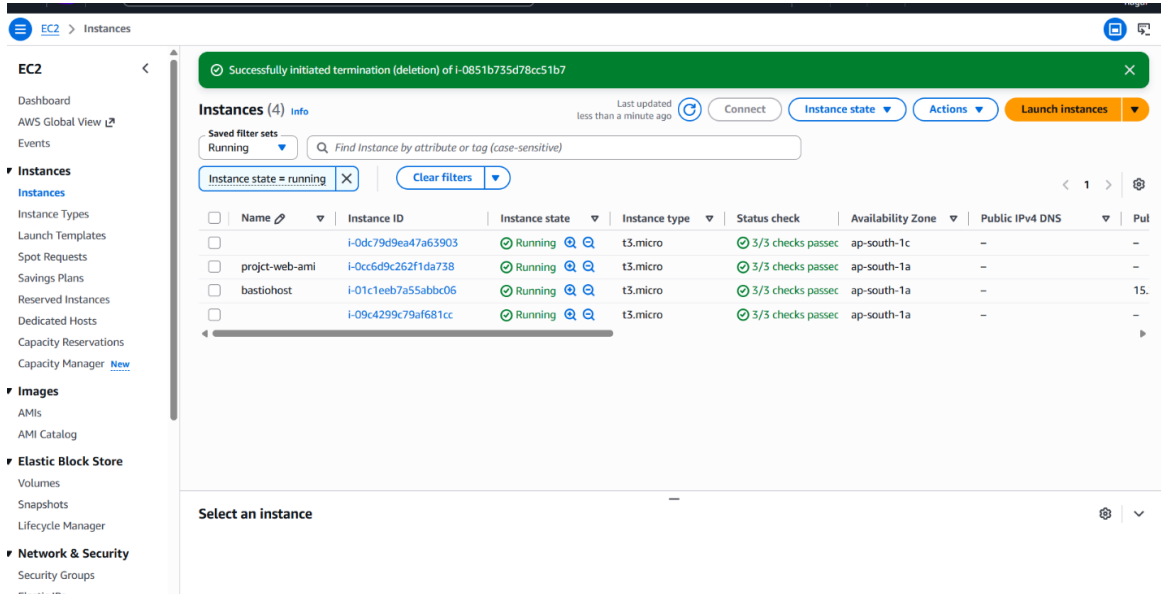
The screenshot shows the AWS Management Console interface for IAM Roles. The left sidebar lists navigation options like IAM, Roles, and Policies. The main content area displays the 'iam-cloudwatch' role details. The 'Permissions policies' tab is active, showing a list of four attached policies: 'AWS Secrets Manager Client Read Only Access', 'AWS Transform Secrets Manager Connect', 'CloudWatchAgentServerPolicy', and 'SecretsManagerReadWrite'.

Policy name	Type	Attached entities
AWS Secrets Manager Client Read Only Access	AWS managed	1
AWS Transform Secrets Manager Connect	AWS managed	1
CloudWatchAgentServerPolicy	AWS managed	1
SecretsManagerReadWrite	AWS managed	1

IAM role — attached permissions policies

11. Bastion Host

The Bastion Host is a Windows Server 2019 instance with a public IP, used exclusively for administrative RDP access. It is the only public entry point into the private network, and its security group restricts inbound RDP to a single trusted IP address.



The screenshot displays the AWS Management Console interface for the EC2 Instances page. A green notification bar at the top indicates the successful termination of instance i-0851b735d78cc51b7. The main content area shows a list of four running instances, with the 'bastionhost' instance highlighted. The instance details table is as follows:

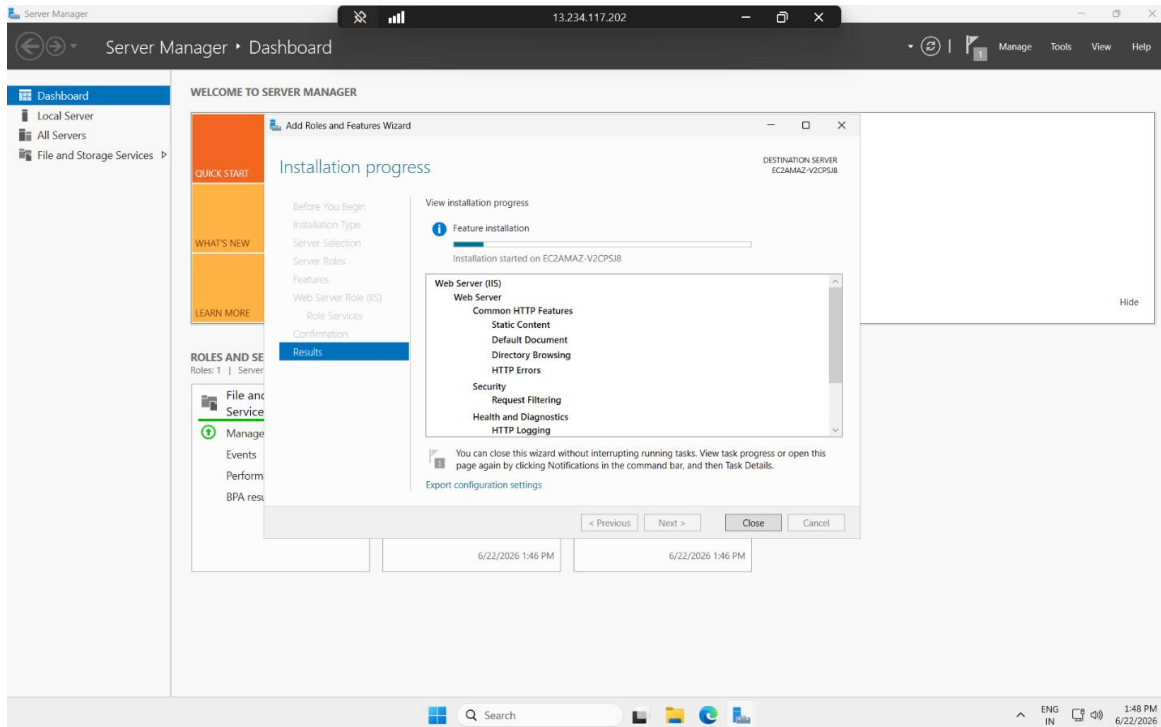
	Name	Instance ID	Instance state	Instance type	Status check	Availability Zone	Public IPv4 DNS	Public IP
☐		i-0dc79d9ea47a63903	Running	t3.micro	3/3 checks passed	ap-south-1c	-	-
☐	projct-web-ami	i-0cc6d9c262f1da738	Running	t3.micro	3/3 checks passed	ap-south-1a	-	-
☐	bastionhost	i-01c1eeb7a55abbc06	Running	t3.micro	3/3 checks passed	ap-south-1a	-	15.179.10.10
☐		i-09c4299c79af681cc	Running	t3.micro	3/3 checks passed	ap-south-1a	-	-

The left sidebar shows the navigation menu with categories like EC2, Images, Elastic Block Store, and Network & Security. The bottom of the console shows a 'Select an instance' dropdown.

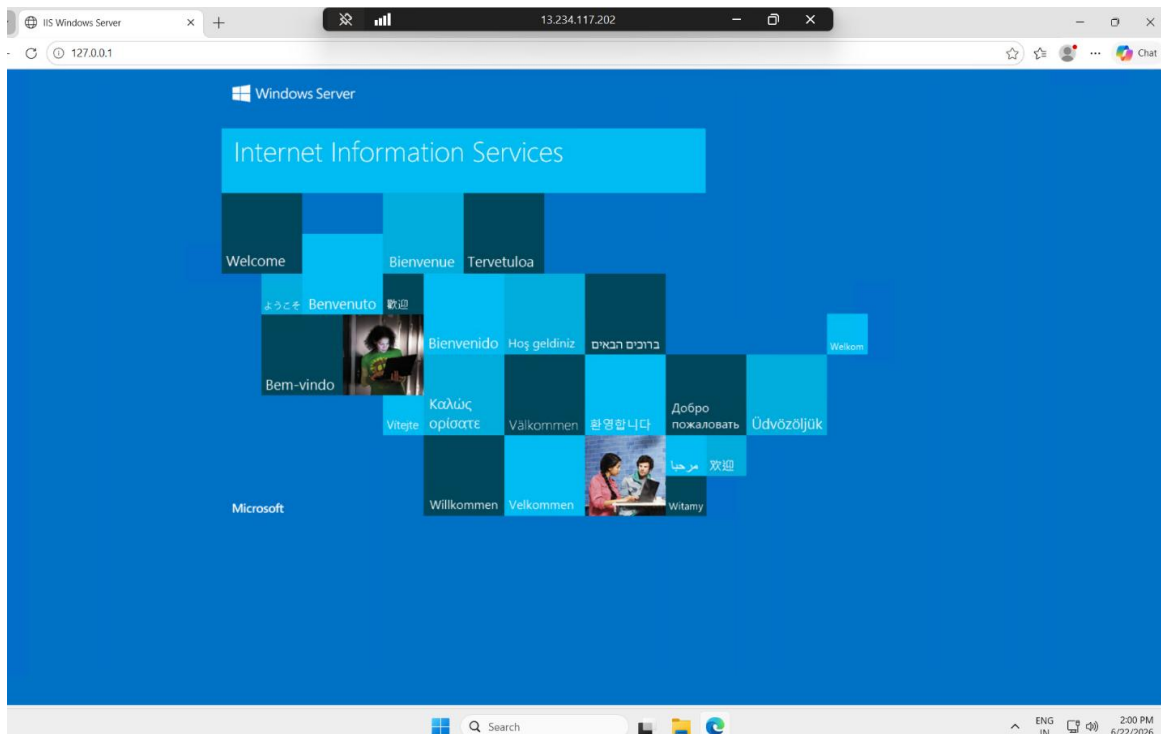
Bastion host instance — details

12. Custom AMI and Web Server Build

A temporary EC2 instance was used to install Windows Server 2019, enable IIS, and deploy the application before being captured as a custom Amazon Machine Image. This AMI is what the Launch Template later uses to launch identical, pre-configured web servers.



Server Manager — installing the IIS web server role



Internet Information Services (IIS) running on the instance

The screenshot shows the AWS Management Console's 'Amazon Machine Images (AMIs)' page. The left sidebar lists navigation options like 'Instances', 'Images', 'Elastic Block Store', and 'Network & Security'. The main content area shows a list of AMIs with columns for Name, AMI name, AMI ID, Source, Owner, and Visibility. The 'project-web-ami' is selected, and its details are shown below. The details include AMI ID, Image type (machine), Platform details (Windows), Root device type (EBS), AMI name (project-web-ami), Owner account ID (369113522455), Architecture (x86_64), Usage operation (RunInstances:0002), Root device name (/dev/sda1), Status (Available), Source (369113522455/project-web-ami), Virtualization type (hvm), Boot mode (-), State reason (-), Creation date (2026-06-11T06:54:38.000Z), Kernel ID (-), Fast launch status (Disabled), Fast launch status reason (-), Fast launch target resource count (-), and Fast launch max parallel launches (-).

AMI ID	Image type	Platform details	Root device type
ami-0c82013308668ad05	machine	Windows	EBS

AMI name	Owner account ID	Architecture	Usage operation
project-web-ami	369113522455	x86_64	RunInstances:0002

Root device name	Status	Source	Virtualization type
/dev/sda1	Available	369113522455/project-web-ami	hvm

Boot mode	State reason	Creation date	Kernel ID
-	-	2026-06-11T06:54:38.000Z	-

Fast launch status	Fast launch status reason	Fast launch target resource count	Fast launch max parallel launches
Disabled	-	-	-

Custom AMI created from the AMI Builder instance

13. Launch Template

The Launch Template defines every parameter a new web server instance needs: the custom AMI, instance type, IAM instance profile, and security group, so that Auto Scaling can launch consistent, ready-to-serve instances on demand.

The screenshot shows the AWS Management Console's 'Launch Templates' page. The left sidebar lists navigation options like 'Dashboard', 'AWS Global View', 'Events', 'Instances', 'Launch Templates', 'Spot Requests', 'Savings Plans', 'Reserved Instances', 'Dedicated Hosts', 'Capacity Reservations', 'Capacity Manager', 'Images', 'Elastic Block Store', and 'Network & Security'. The main content area shows a list of Launch Templates with columns for Launch Template ID, Launch Template Name, Default Version, Latest Version, Create Time, and Created By. The 'template-for-websec' is selected, and its details are shown below. The details include Launch Template ID (lt-090d5d21e9ae5fa41), Launch Template Name (template-for-websec), Default Version (1), Latest Version (2), Create Time (2026-06-11T13:47:03.000Z), and Created By (arn:aws:iam::369113522455:root). The 'Launch template version details' section shows the Version (1 (Default)), Description (template-for-websec), Date created (2026-06-11T13:47:03.000Z), and Created by (arn:aws:iam::369113522455:root). The 'Instance details' section shows the AMI ID (ami-0c82013308668ad05), Instance type (t3.micro), Availability Zone (-), Availability Zone Id (-), Key pair name (bastionhost), Security groups (-), and Security group IDs (sg-02e10f18622c6e029).

Launch Template ID	Launch Template Name	Default Version	Latest Version	Create Time	Created By
lt-090d5d21e9ae5fa41	template-for-websec	1	2	2026-06-11T13:47:03.000Z	arn:aws:iam::369113522455:root

Launch Template ID	Launch Template Name	Default Version	Latest Version	Create Time	Created By
lt-090d5d21e9ae5fa41	template-for-websec	1	2	2026-06-11T13:47:03.000Z	arn:aws:iam::369113522455:root

Version	Description	Date created	Created by
1 (Default)	template-for-websec	2026-06-11T13:47:03.000Z	arn:aws:iam::369113522455:root

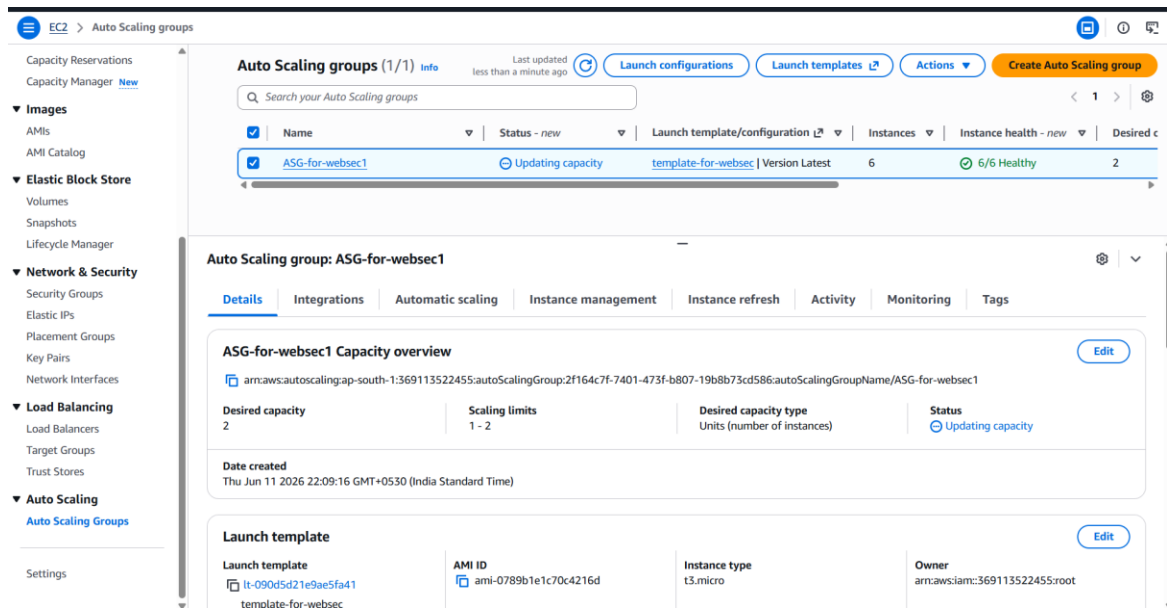
AMI ID	Instance type	Availability Zone	Availability Zone Id
ami-0c82013308668ad05	t3.micro	-	-

Key pair name	Security groups	Security group IDs
bastionhost	-	sg-02e10f18622c6e029

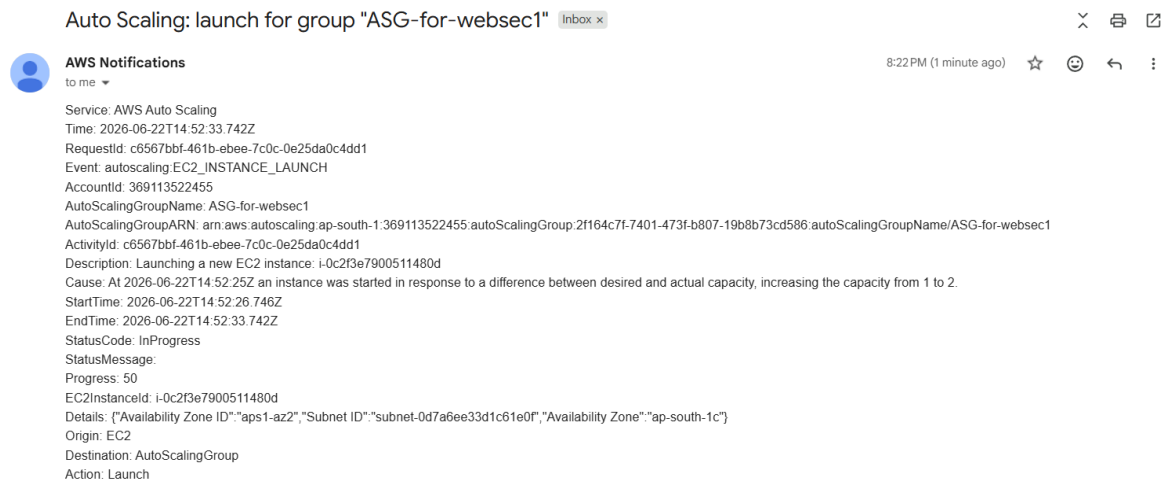
Launch Template — template details

14. Auto Scaling Group

The Auto Scaling Group is configured with a minimum, desired, and maximum capacity of two instances, spread across both Availability Zones, so the application keeps running even if an entire zone becomes unavailable.



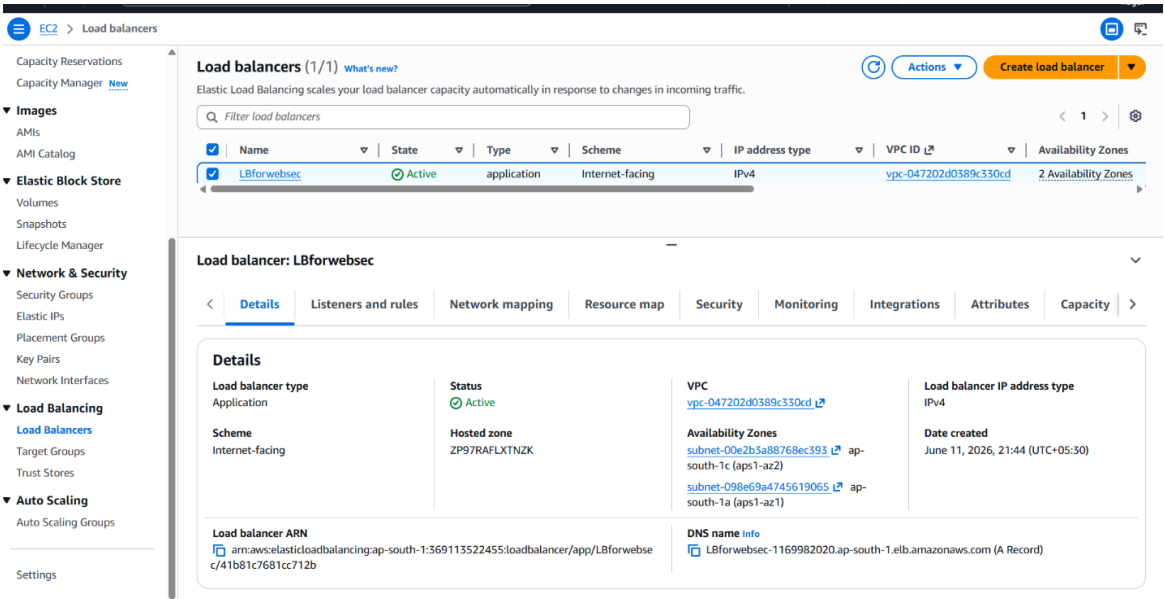
Auto Scaling group — capacity overview



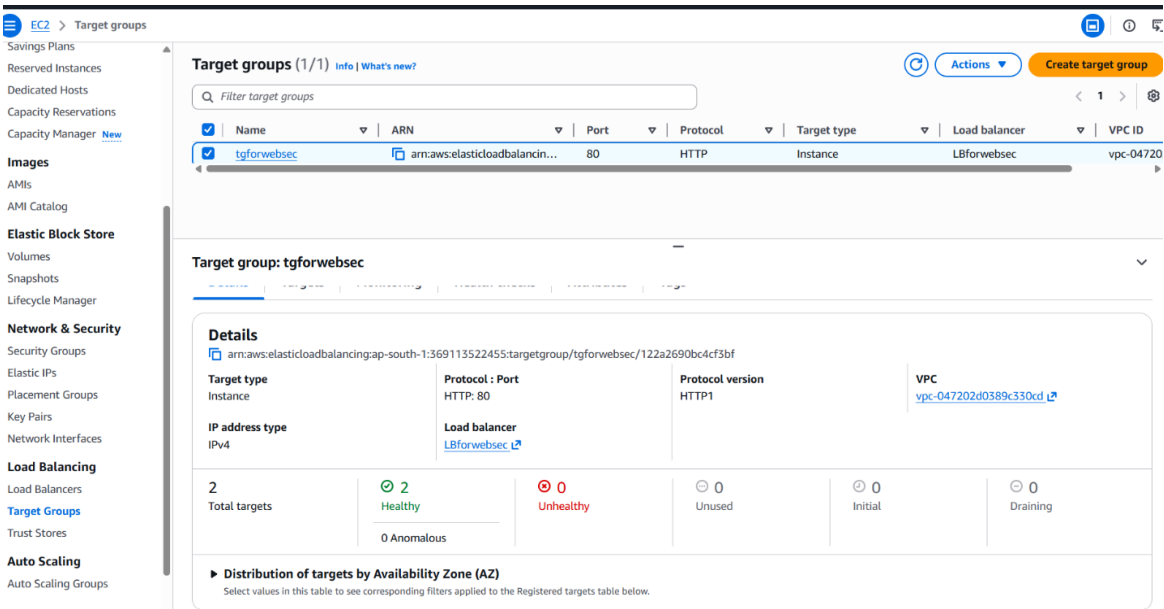
Auto Scaling launch notification for ASG-for-websec1

15. Load Balancer

An internet-facing Application Load Balancer listens on HTTP port 80 and forwards traffic to a target group containing both web server instances, performing health checks to route around any unhealthy instance.



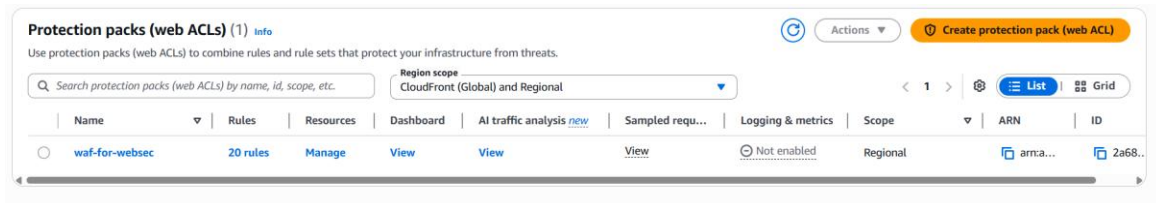
Application Load Balancer — details



Target group — registered web server targets

16. AWS WAF

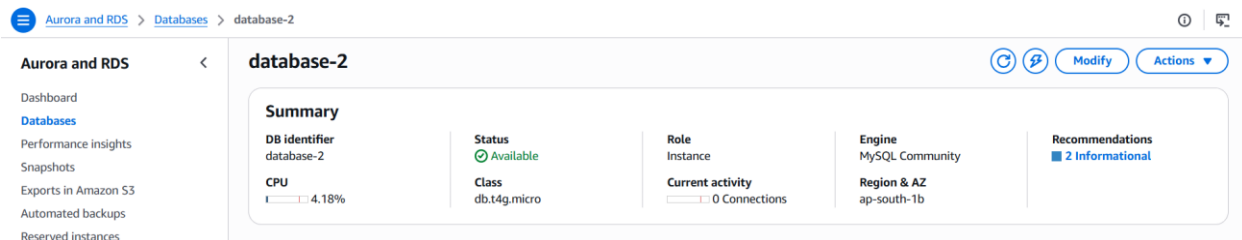
AWS WAF is associated directly with the ALB and inspects every request before it reaches the application, blocking common web exploits and unwanted traffic patterns using managed rule sets.



AWS WAF — Web ACL protection packs

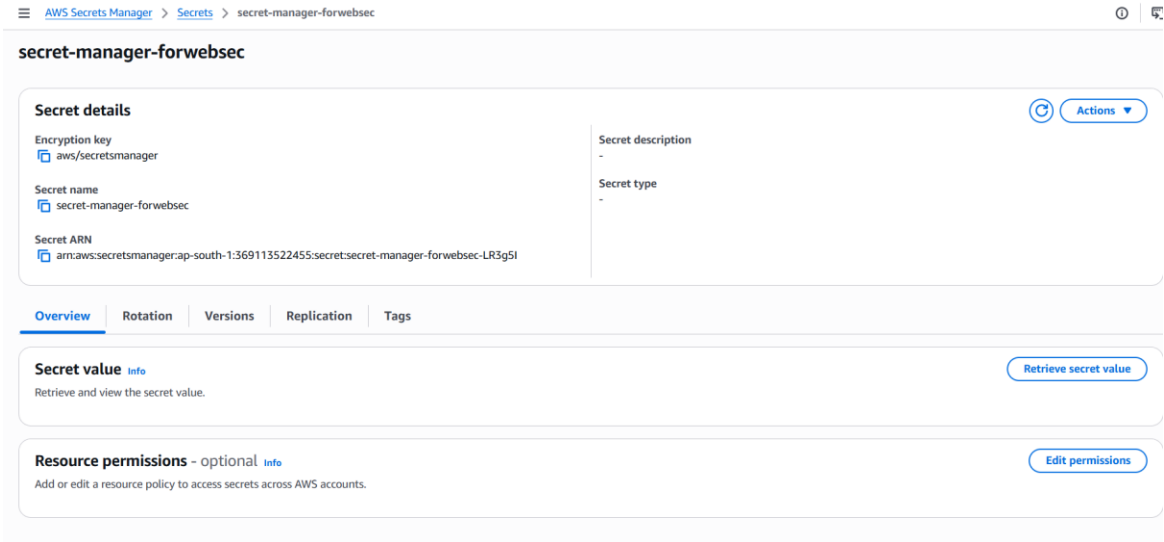
17. Amazon RDS

Amazon RDS for MySQL hosts the application's database within the private database subnet. The database is accessible only from the web server security group over **TCP port 3306** and has **no public endpoint**, preventing direct internet access. Storage encryption at rest is enabled using the **AWS-managed KMS key (aws/rds)**, protecting the database, automated backups, and snapshots without requiring manual key management.



18. AWS Secrets Manager

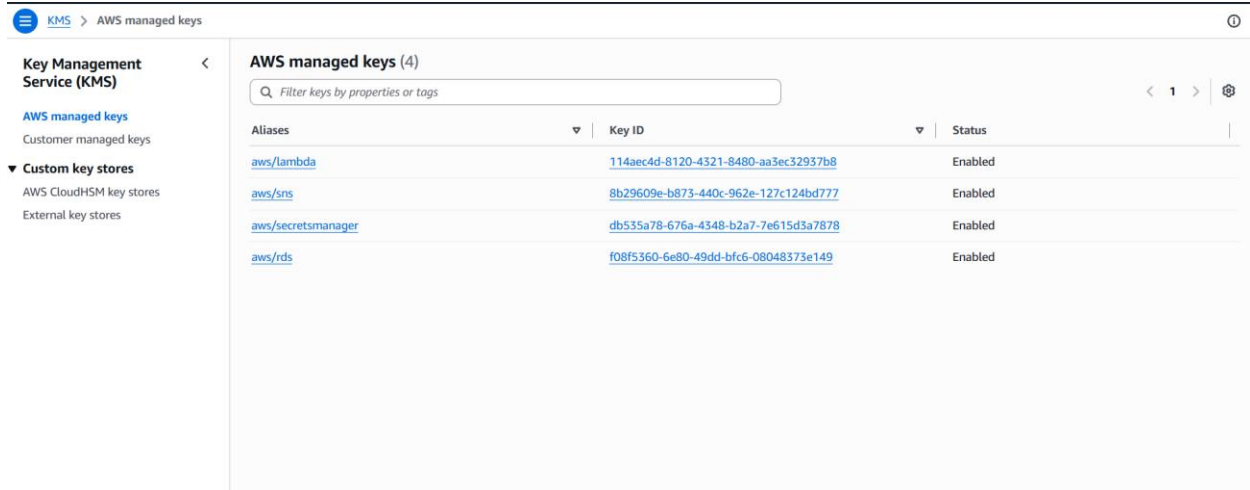
Database credentials are never stored on the web servers. Instead, the application retrieves the username and password at runtime from AWS Secrets Manager, using the IAM role attached to each EC2 instance.



Secrets Manager — secret-manager-forwebsec

19. AWS KMS

AWS Key Management Service (KMS) provides encryption keys for multiple AWS services used in this project. The Amazon RDS instance is encrypted using the AWS-managed **aws/rds** KMS key, ensuring that database storage, automated backups, and snapshots are encrypted at rest. Additionally, AWS-managed KMS keys are available for services such as **AWS Secrets Manager (aws/secretsmanager)** and **Amazon SNS (aws/sns)**, providing encryption support for stored secrets and notification data where applicable. These AWS-managed keys eliminate the need for manual key administration while maintaining secure encryption across AWS services.

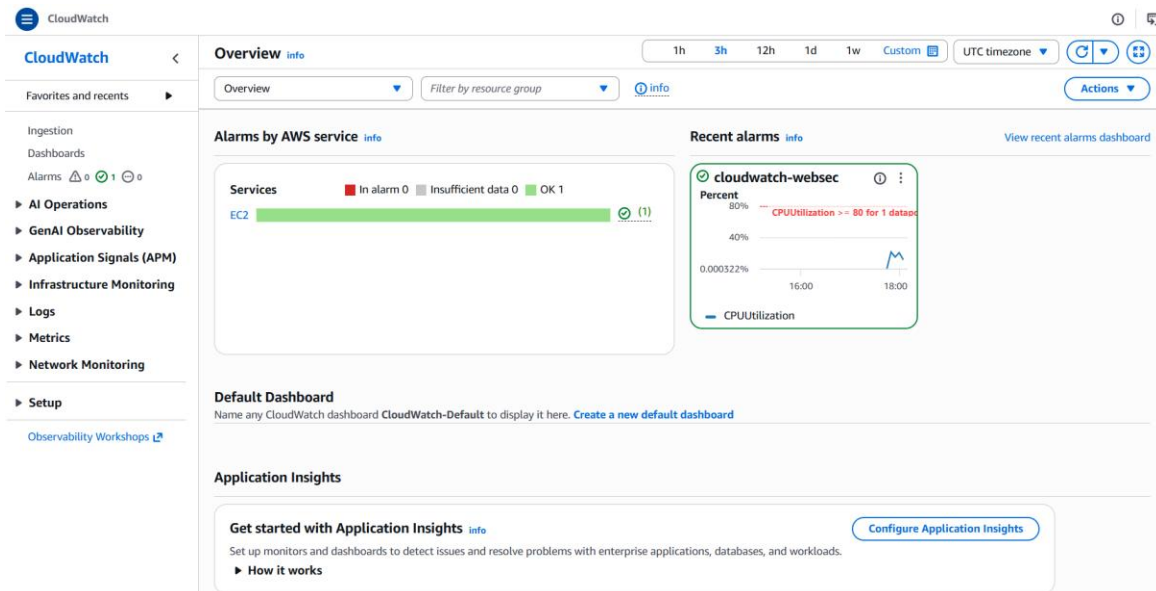


The screenshot shows the AWS Management Console interface for the Key Management Service (KMS). The left sidebar contains navigation links for 'Key Management Service (KMS)', 'AWS managed keys', 'Customer managed keys', and 'Custom key stores'. The main content area is titled 'AWS managed keys (4)' and features a search bar and a table of managed keys. The table has columns for Aliases, Key ID, and Status. Four keys are listed, all with a status of 'Enabled'.

Aliases	Key ID	Status
aws/lambda	114aec4d-8120-4321-8480-aa3ec32937b8	Enabled
aws/sns	8b29609e-b873-440c-962e-127c124bd777	Enabled
aws/secretsmanager	db535a78-676a-4348-b2a7-7e615d3a7878	Enabled
aws/rds	f08f5360-6e80-49dd-bfc6-08048373e149	Enabled

20. Amazon CloudWatch

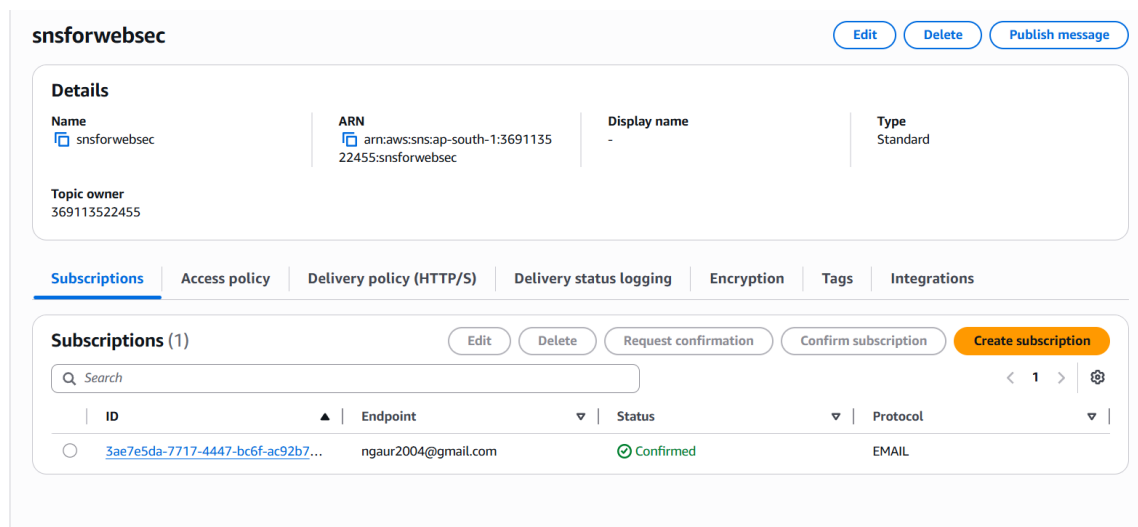
CloudWatch monitors EC2 CPU utilization for the web tier and raises an alarm when usage crosses an 80% threshold, giving early warning of load that may require scaling.



CloudWatch — alarms and dashboard overview

21. Amazon SNS

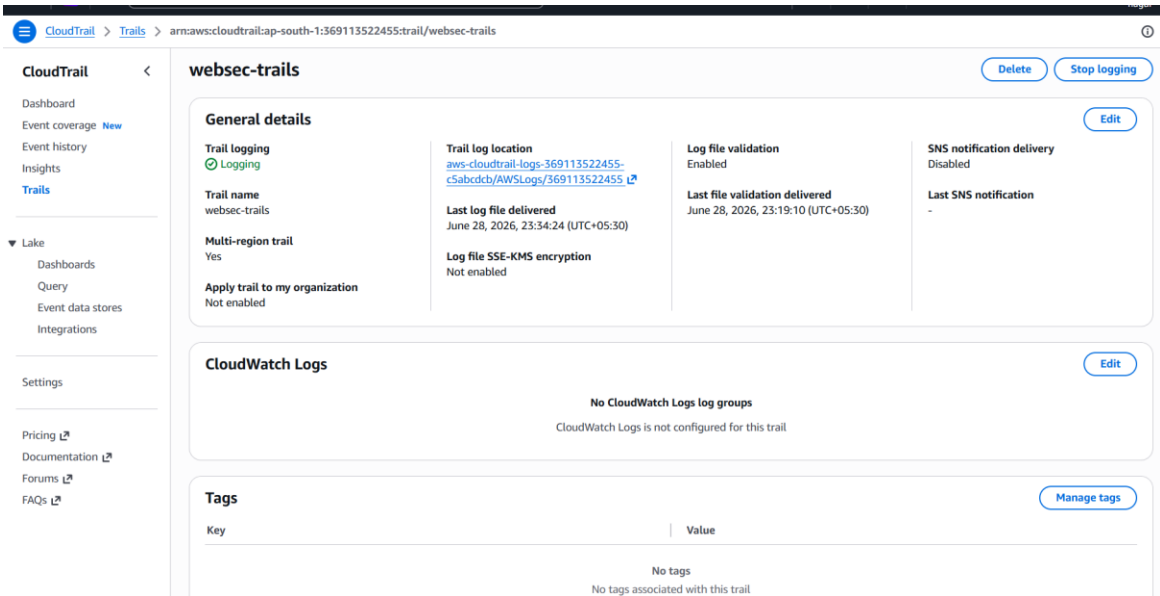
When a CloudWatch alarm fires, it publishes to an SNS topic that immediately emails the operations team, closing the loop between detection and human awareness.



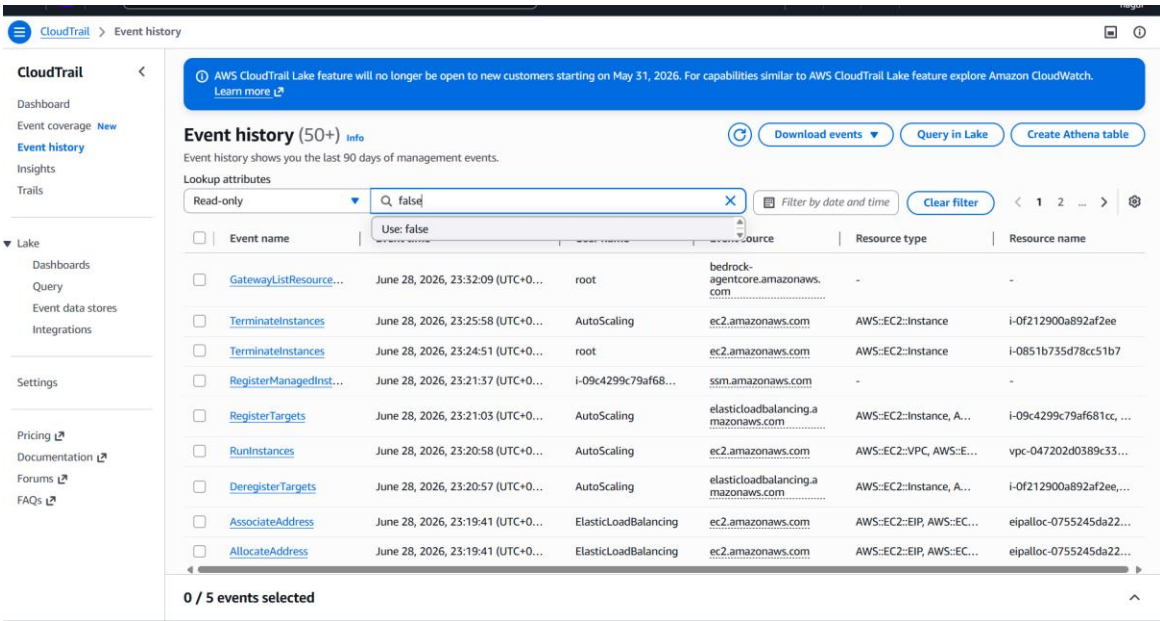
SNS topic — snsforwebsec subscription

22. AWS CloudTrail

CloudTrail records every API call made against the AWS account — who made it, when, and from where — providing a complete audit trail for security review and compliance.



CloudTrail — websec-trails configuration



CloudTrail — event history

23. Amazon S3

CloudTrail logs are delivered to a dedicated S3 bucket, providing durable, centralized storage for audit history that can be reviewed long after the events occurred.

24. Traffic Flow

Application Request Flow

1. Client sends an HTTP request over the internet.
2. Request enters the VPC through the Internet Gateway.
3. AWS WAF inspects and filters the request.
4. The Application Load Balancer receives the filtered request.
5. The request is forwarded to the Target Group.
6. An EC2 Web Server processes the request via IIS.
7. The web server queries Amazon RDS MySQL over port 3306 if needed.
8. The response travels back through the same path to the client.

Administrative Access Flow

9. Administrator connects via RDP to the Bastion Host using its public IP.
10. From the Bastion Host, the administrator RDPs into a private web server.

25. Security Best Practices Applied

- Network segmentation across public, private-web, and private-database subnets.
- Least-privilege IAM roles instead of long-lived access keys on instances.
- Database deployed in a private subnet with no public endpoint.
- Credentials stored in AWS Secrets Manager rather than hard-coded in application config.
- AWS WAF protecting the application from common web exploits.
- AWS KMS encryption for data at rest on RDS.
- Multi-AZ RDS deployment for automatic failover.
- CloudTrail auditing of all API activity.
- CloudWatch monitoring with SNS alerting.
- Auto Scaling for resilience and elasticity.
- Bastion Host as the sole path for administrative access.

26. Challenges Faced

- Understanding how route tables determine traffic flow between public and private subnets.
- Correctly scoping security group rules so each tier only accepts traffic from the tier above it.
- Attaching the right IAM permissions to the EC2 role without over-granting access.
- Configuring the Launch Template to consistently produce working instances from the custom AMI.

27. Future Improvements

- Add HTTPS using an AWS Certificate Manager (ACM) certificate and an HTTPS listener.
- Enable AWS Shield Advanced for enhanced DDoS protection.
- Replace the Bastion Host with AWS Systems Manager Session Manager for keyless administrative access.
- Enable AWS Config for continuous compliance monitoring.
- Enable Amazon GuardDuty for threat detection.
- Enable VPC Flow Logs for deeper network visibility.
- Migrate the manual setup to Infrastructure as Code using Terraform or AWS CloudFormation.
- Build a CI/CD pipeline with GitHub Actions for automated deployment.

28. Conclusion

This project delivered a secure, highly available, three-tier web application on AWS, built around network segmentation, least-privilege access, encryption at rest, and continuous monitoring. Working through VPC design, security group scoping, IAM permissions, Auto Scaling, and credential management provided hands-on experience with the core practices of cloud security engineering, and produced an architecture that reflects real-world production patterns rather than a simplified lab exercise.